PENSE-BÊTE · CONCEPTS RÉSEAU ET ARCHITECTURE

Protocole Kerberos et Active Directory

06-640 PSE 25-27 5-6 Active Directory - Kerberos — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. Kerberos sécurise les communications en environnement non sécurisé grâce à un système de tickets et permet l'authentification mutuelle entre le client et le serveur.
2. Le KDC agit comme tiers de confiance hébergé sur les contrôleurs de domaine en utilisant les sous-services AS et TGS pour authentifier les acteurs.
3. La sécurité du protocole est renforcée par l'utilisation de l'AES-256 et la protection contre les attaques comme le Golden Ticket qui falsifie un TGT via la clé du compte krbtgt.

Kerberos : Fondamentaux

Notion	À retenir
Définition	Protocole d'authentification basé sur des **tickets** pour sécuriser les communications en environnement non sécurisé.
Comparaison NTLM	NTLM est **moins sécurisé** : utilise des hachages **MD4** ou **MD5** et vulnérable au **pass-the-hash**.
Authentification mutuelle	Vérification de l'identité du **client** et du **serveur** pour garantir la bonne communication.

Acteurs principaux de Kerberos

Notion	À retenir
Trois acteurs principaux	Le **client** (demande l'accès), le **serveur de service** (fournit la ressource) et le **KDC** (tiers de confiance).
Rôle du KDC	Hébergé sur les **contrôleurs de domaine AD**, il authentifie utilisateurs et services via l'**AS** et le **TGS**.
Tickets et authentificateurs	**TGT** (initial), **TS** (accès ressource spécifique) et **authenticator** (preuve d'identité temporaire contre le rejeu).

Processus d'authentification Kerberos

Notion	À retenir
Authentification initiale	Client envoie `KRB_AS_REQ` au KDC. Réponse `AS-REP` contenant un **TGT** (clé KDC) et une **clé de session** (mot de passe client).
Obtention ticket service	Client envoie `KRB_TGS_REQ` (avec **TGT** + authentificateur). KDC répond `KRB_TGS_REP` avec un **ticket de service** chiffré avec la **clé à long terme** du service cible (connue du seul KDC et du service).
Accès ressource	Client envoie `KRB_AP_REQ` au serveur. Le serveur répond `KRB_AP_REP` pour une **authentification mutuelle**. La **LSA** crée un jeton d'accès sur le client.

Synthèse AD et Kerberos

Notion	À retenir
Rôle DC et base	La base AD stocke comptes, services et **clés secrètes**. Chaque DC est un **KDC** synchronisé par **réplication AD**.
Comptes et SPN	Comptes service identifiés par **SPN** (ex: `HTTP/serveur.domaine.com`). Vérification : `setspn -L NOM_COMPTE`.
Politiques et clés	Clés dérivées des mots de passe. Mise à jour comptes ordinateur : **30 jours** par défaut. Configuration via **Default Domain Policy**.

Sécurité Kerberos : menaces, protection et surveillance

Notion	À retenir
Attaques Kerberos	**Golden Ticket** (falsification TGT via clé `krbtgt`), **Silver Ticket** (falsification ticket de service), **Kerberoasting** (extraction hachages tickets de service).
Protection et durcissement	Réinitialiser `krbtgt` **2 fois de suite** (en respectant la réplication) (script `New-KrbtgtKeys.ps1`), mots de passe **forts** comptes de service, chiffrement **AES-256** (préféré à RC4).
Surveillance et journalisation	Vérifier les événements **4768** et **4769** dans l'Observateur d'événements (journalisation détaillée : voir dépannage).

Diagnostic et dépannage Kerberos

Notion	À retenir
Commandes de diagnostic	`klist` (tickets, `klist tgt` pour **TGT**), `nltest /dsgetdc:DOMAINE` (KDC), `nltest /sc_query:DOMAINE` (confiance), `setspn` (SPN : `-L`, `-s`, `-Q`)
Résolution d'erreurs	`KRB_AP_ERR_MODIFIED` : **SPN dupliqué** ou mauvais compte. `KRB_AP_ERR_SKEW` : **décalage d'horloge** (utiliser `w32tm /resync`)
Configuration logging	Chemin : `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\Kerberos\Parameters`. Valeur : `LogLevel` (**REG_DWORD**) réglée sur `0x1` pour l'**Observateur d'événements**

Pièges et confusions

- ⚠ Confondre le TGT qui est le ticket initial avec le TS qui est le ticket de service
- ⚠ Confondre le KDC avec ses deux sous services nommés AS et TGS
- ⚠ Oublier que l'authentification mutuelle permet au client et au serveur de vérifier leur identité réciproquement
- ⚠ Confondre KRB_AP_ERR_MODIFIED (SPN incorrect, dupliqué ou clé non correspondante) avec KRB_AP_ERR_SKEW (horloge désynchronisée)

Sigles et définitions

KDC Key Distribution Center, tiers de confiance hébergé sur les contrôleurs de domaine

TGT Ticket Granting Ticket, ticket initial utilisé pour demander des tickets de service

SPN Service Principal Name, identifiant unique permettant de nommer un service dans le domaine

AS Authentication Service, sous-service du KDC chargé d'authentifier le client et de délivrer le TGT

TGS Ticket Granting Service, sous-service du KDC fournissant des tickets de service basés sur le TGT

LSA Local Security Authority, autorité sur l'ordinateur client créant un jeton d'accès

Auto-test

1. Pourquoi Kerberos remplace-t-il NTLM ?
2. Quelle attaque consiste à falsifier un TGT avec des privilèges élevés ?
3. Quelle commande permet de vérifier les tickets ?
4. Que signifie l'erreur KRB_AP_ERR_SKEW ?
5. Comment s'appelle l'attaque consistant à extraire les hachages de tickets de service ?

Réponses : **1.** NTLM utilise des hachages moins robustes (MD4 ou MD5) · **2.** Golden Ticket · **3.** klist · **4.** Une horloge désynchronisée · **5.** Kerberoasting

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.